

Cahier des charges

Projet de bachelor ISC – Infrastructure DNSSEC sécurisée et crypto-agile

HEPIA – Filière ISC, Orientation Sécurité informatique

1 Contexte et enjeux

Établissement : Haute école du paysage, d'ingénierie et d'architecture de Genève (HEPIA)

Filière : Informatique et Systèmes de Communication (ISC) – Orientation Sécurité informatique

Étudiant : El Hakouni Yassin

Enseignant responsable : Prof. El Maliki Tewfiq

Entreprise : Aucune (projet académique)

Confidentialité : Non confidentiel

La sécurité des réseaux informatiques est un enjeu majeur face à la multiplication des cyberattaques, à l'interconnexion croissante des systèmes et à l'émergence de nouvelles menaces, notamment liées au *quantum computing*. Les services d'infrastructure comme le DNS constituent des cibles de choix (DDoS, empoisonnement de cache, détournement de trafic, exfiltration de données via DNS, etc.).

Le projet s'inscrit dans ce contexte et vise :

- à déployer une **infrastructure DNSSEC** robuste sur un réseau local de laboratoire ;
- à **sécuriser le flux des données** associées (résolution, transfert de zones, supervision, accès d'administration) ;
- à **mettre en place une détection d'attaques** ciblant les services déployés ;
- à **étudier et proposer un scénario de déploiement cloud** avec comparaison technique, économique et en termes de qualité de service ;
- à **intégrer un volet de crypto-agilité** montrant la capacité de l'architecture à faire évoluer ses primitives cryptographiques (par exemple vers des solutions post-quantiques) sans refonte complète.

Le projet se déroule en deux phases :

- **Phase 1 – Projet de semestre** (livrables mi-janvier 2026, soutenance quelques jours plus tard) : mise en place de l'infrastructure locale, des mécanismes de sécurité et d'une première preuve de concept de détection d'attaques, plus un premier micro-PoC de crypto-agilité.
- **Phase 2 – Projet de bachelor** (finalisation et soutenance début septembre 2026) : approfondissement, industrialisation, extension au cloud, renforcement de la crypto-agilité et rédaction du rapport final de bachelor.

2 Objectifs du projet

2.1 Objectif général

Concevoir, déployer et documenter une **infrastructure DNSSEC sécurisée et crypto-agile**, avec capacités de **détection d'attaques** et **projection vers un déploiement cloud**, afin

de fournir une recommandation argumentée pour une mise en production dans un contexte professionnel.

2.2 Objectifs spécifiques

2.2.1 DNSSEC sur réseau local

- Déployer un ou plusieurs serveurs DNS faisant autorité et/ou serveurs de résolution validant DNSSEC.
- Signer au moins une zone locale avec DNSSEC (gestion des clés KSK/ZSK, signatures, RRSIG, DS, etc.).
- Documenter le processus de génération, stockage, rotation et révocation des clés.

2.2.2 Sécurisation du flux de données

- Sécuriser les communications entre résolveurs et serveurs faisant autorité (par exemple TSIG pour les transferts de zone, sécurisation de l'administration en SSH/TLS, éventuellement DNS over TLS/HTTPS selon le périmètre choisi).
- Mettre en place une segmentation réseau adaptée (VLAN, pare-feux, DMZ) pour isoler les services DNS et limiter l'impact d'une compromission.

2.2.3 Détection d'attaques liées aux services déployés

- Définir un scénario d'attaques réaliste (par exemple empoisonnement de cache, amplification DNS, zone transfer non autorisé, tunneling DNS, bruteforce de sous-domaines, etc.).
- Déployer des outils de détection (IDS/IPS, analyse de logs, corrélation d'événements) capables d'identifier ces attaques sur le trafic DNS et réseau.
- Produire un **rapport d'analyse des détections** (types d'attaques, logs/alertes générés, faux positifs/négatifs, limites).

2.2.4 Projection et comparaison d'un déploiement cloud

- Proposer une architecture cible dans le cloud (par exemple DNS managé et composants de sécurité associés).
- Comparer l'architecture locale et l'architecture cloud selon des critères techniques (performance, résilience, sécurité), économiques (coûts CAPEX/OPEX estimés) et de qualité de service (latence, disponibilité, scalabilité).
- Formuler une **recommandation chiffrée et argumentée** concernant l'option la plus adaptée dans un contexte donné.

2.2.5 Intégration de la crypto-agilité

- Définir ce qu'est la **crypto-agilité** dans le contexte du projet : capacité à remplacer ou faire coexister plusieurs algorithmes (DNSSEC, TLS, VPN, etc.) sans interrompre le service.
- Concevoir au moins un **PoC de crypto-agilité**, par exemple :
 - support de plusieurs algorithmes DNSSEC (RSASHA256, ECDSAP256SHA256, etc.) avec procédures documentées de migration ;

- automatiser la rotation de certificats/clefs avec possibilité de changer de suite cryptographique via configuration ;
- introduction d'un composant « abstrait » (API, rôle Ansible, script d'orchestration) permettant de reconfigurer facilement les primitives cryptographiques.
- Préparer le terrain pour une **évolution vers des algorithmes post-quantiques ou hybrides** dans la phase bachelor (sans obligation de les déployer réellement en production, mais avec une réflexion claire sur la migration).

3 Périmètre fonctionnel

3.1 Services à mettre en place

- Au minimum une **zone DNS locale** signée par DNSSEC.
- Un ou plusieurs **clients** effectuant des requêtes DNS via le réseau de labo.
- Un **serveur de logs / supervision** centralisant les traces DNS et les alertes de sécurité.
- Un ou plusieurs **capteurs de détection** (IDS/IPS, analyseur de flux, etc.).
- Un **pare-feu** ou des règles de filtrage réseau protégeant les services.
- Des **outils d'attaque contrôlée** (environnement de test) pour générer le trafic malveillant.

3.2 Fonctions couvertes

3.2.1 Résolution DNS classique et DNSSEC

- Résolution des noms internes du labo.
- Validation des signatures DNSSEC côté résolveur.

3.2.2 Administration sécurisée

- Accès administrateur aux serveurs via des canaux sécurisés.
- Journalisation des actions sensibles.

3.2.3 Collecte et analyse de logs

- Centralisation des logs DNS, système et sécurité.
- Mise en place de tableaux de bord simples (par exemple volumétrie, top requêtes, top erreurs, alertes sécurité).

3.2.4 Détection d'attaques

- Règles ou signatures capables de détecter les scénarios d'attaques définis.
- Notification ou au minimum enregistrement clair de ces événements.

3.2.5 Crypto-agilité (fonctionnalités minimales pour le PoC)

- Documentation et scripts permettant de **changer d'algorithme** ou de **taille de clé** sans devoir redéployer l'infrastructure complète.
- Capacité à repasser rapidement à un algorithme « sûr » si un algorithme est déprécié.

3.3 Hors périmètre (à expliciter)

- Sécurisation exhaustive de l'ensemble d'un SI de production (le projet reste un **labo représentatif**).
- Certification formelle des composants.
- Intégration avec des systèmes SIEM/EDR complexes au-delà d'un périmètre de démonstration.

4 Contraintes et hypothèses

4.1 Contraintes organisationnelles

- **Calendrier académique :**
 - Livrables de la phase semestre à remettre **mi-janvier 2026** (date exacte confirmée par l'enseignant).
 - Soutenance de semestre quelques jours après la remise.
 - Phase de continuation et d'enrichissement jusqu'à **début septembre 2026** (soutenance de bachelor).
- Charge de travail compatible avec un projet individuel de bachelor ISC.

4.2 Contraintes techniques

- Utilisation principale de technologies **open-source** lorsque cela est possible (serveurs DNS type BIND/NSD/Knot, IDS/IPS, etc.).
- Infrastructure hébergée sur des ressources disponibles (VMs de labo HEPIA, hyperviseur local, etc.).
- Accès Internet limité ou contrôlé selon les politiques de l'école.
- Documentation en **français** (langue d'enseignement), avec éventuellement un court résumé en anglais si demandé.

4.3 Contraintes de sécurité

- Les scénarios d'attaque doivent rester **strictement confinés au labo** et ne cibler aucun système réel externe.
- Respect des bonnes pratiques de gestion de clés (pas de publication de secrets dans les rapports, dépôt Git, etc.).

4.4 Hypothèses

- Les ressources matérielles et logicielles nécessaires (VM, stockage, droits administrateur) seront disponibles.
- L'enseignant valide le périmètre et la profondeur technique proposée.

5 Livrables

5.1 Livrables phase 1 (projet de semestre – mi-janvier 2026)

5.1.1 Infrastructure locale opérationnelle

- Serveur(s) DNS et DNSSEC fonctionnels.
- Scénarios d’attaques et de détection mis en œuvre.

5.1.2 Rapport intermédiaire (20–30 pages indicatives)

- Contexte, état de l’art, choix techniques.
- Description détaillée de l’architecture locale.
- Procédures de configuration et de tests.
- Résultats des scénarios d’attaque et de détection.
- Première implémentation de la crypto-agilité (PoC simple) et limitations.

5.1.3 Démonstration / soutenance de semestre

- Présentation de l’architecture.
- Démonstration de la résolution DNSSEC.
- Démonstration de la détection d’au moins un scénario d’attaque.

5.2 Livrables phase 2 (projet de bachelor – début septembre 2026)

5.2.1 Architecture enrichie et stabilisée

- Améliorations côté sécurité, monitoring et crypto-agilité.
- Ajout de la partie cloud (maquette, étude ou PoC selon faisabilité).

5.2.2 Rapport final de bachelor

Version complète et consolidée du rapport, incluant l’étude cloud, la comparaison technique/économique et une partie approfondie sur la crypto-agilité (concept, mise en œuvre, *roadmap* post-quantiques éventuelle).

5.2.3 Recommandation de déploiement cloud

Document de synthèse chiffré et argumenté (coûts estimés, avantages/inconvénients, risques) pour une organisation type.

5.2.4 Soutenance finale

Présentation orale avec démonstration (si possible) et discussion sur les choix de sécurité et de crypto-agilité.

6 Planification prévisionnelle

6.1 Phase 1 – Semestre (jusqu’à mi-janvier 2026)

- **Semaines 1–2 :**
 - Finalisation du cahier des charges et validation par l’enseignant.
 - Revue rapide de l’état de l’art sur DNSSEC, attaques DNS, crypto-agilité.
- **Semaines 3–5 :**
 - Mise en place des VMs / de l’infrastructure réseau de labo.
 - Installation et configuration de base des serveurs DNS.
- **Semaines 6–8 :**
 - Activation de DNSSEC sur la ou les zone(s) locales.
 - Tests de résolution et de validation DNSSEC.
- **Semaines 9–11 :**
 - Mise en place des outils de détection (IDS/IPS, logs, tableaux de bord simples).
 - Conception et exécution des scénarios d’attaque.
- **Semaines 12–13 :**
 - PoC initial de crypto-agilité (scripts, procédures de changement d’algorithme ou de clé).
 - Rédaction du rapport intermédiaire.
- **Semaines 14–15 :**
 - Finalisation, relecture, préparation de la soutenance.

6.2 Phase 2 – Projet de bachelor (janvier 2026 – septembre 2026)

- **Janvier–mars 2026 :**
 - Retour de l’enseignant sur la phase 1.
 - Renforcement de l’architecture, réduction des points faibles identifiés.
- **Mars–mai 2026 :**
 - Étude et conception du scénario cloud (architecture cible, choix du fournisseur, chiffrage, estimation de la QoS).
 - Éventuel PoC sur un environnement cloud de test.
- **Mai–juillet 2026 :**
 - Approfondissement de la crypto-agilité : abstraction des primitives cryptographiques, documentation d’une stratégie de migration (incluant les enjeux post-quantiques).
 - Consolidation de la détection d’attaques et des tableaux de bord.
- **Août 2026 :**
 - Finalisation du rapport de bachelor.
 - Préparation de la soutenance (slides, démonstrations, annexes techniques).

7 Ressources nécessaires

7.1 Matériel / infrastructure

- Accès à un hyperviseur ou à plusieurs VMs (serveurs DNS, IDS/IPS, client(s), serveur de logs).
- Accès réseau de labo avec possibilité de créer des VLAN / segments.

7.2 Logiciels

- Serveur DNS (BIND, NSD, KnotDNS ou équivalent).
- Outils de gestion de clés DNSSEC (utilitaires associés).
- Outil de détection (Snort, Suricata, Zeek ou équivalent) et/ou analyse de logs.
- Système de centralisation de logs (par exemple stack ELK, ou solution plus légère selon le temps disponible).

7.3 Documentation / références

- RFC et guides sur DNSSEC, attaques DNS, bonnes pratiques de déploiement.
- Guides et documents récents sur la **crypto-agilité** et la transition post-quantiques.

8 Indicateurs de réussite

- DNSSEC opérationnel sur la zone locale avec validation correcte des signatures.
- Capacité à démontrer au moins un scénario d'attaque et sa détection par les outils déployés.
- Documentation claire permettant à un tiers de reproduire l'architecture.
- PoC fonctionnel de crypto-agilité (changement d'algorithme ou de paramètres cryptographiques sans interruption majeure du service).
- Comparaison argumentée entre déploiement local et cloud, avec estimation chiffrée des coûts et de la QoS.
- Qualité globale du rapport (structure, clarté, profondeur technique) et de la soutenance.

9 Risques et mesures d'atténuation

- **Risque** : Sous-estimation du temps nécessaire à la mise en place de DNSSEC.
Atténuation : Prioriser rapidement une configuration minimale fonctionnelle avant d'ajouter des fonctionnalités avancées.
- **Risque** : Difficultés techniques avec les outils de détection ou les scénarios d'attaque.
Atténuation : Commencer avec des scénarios simples (par exemple zone transfer non autorisé, requêtes anormales) avant de viser des attaques plus avancées.
- **Risque** : Manque de ressources (VM, droits, etc.).
Atténuation : Aligner tôt avec l'enseignant et l'infrastructure de l'école pour réserver les ressources nécessaires.
- **Risque** : Complexité excessive de la crypto-agilité par rapport au temps disponible.
Atténuation : Limiter la phase 1 à un PoC simple et réserver les scénarios avancés (PQC, hybridation, etc.) à la phase bachelor.

Ce cahier des charges pourra être ajusté et précisé après discussion avec le professeur encadrant afin de valider le périmètre et la charge de travail définitive pour le projet de semestre et le projet de bachelor.